

ShieldDome 技术概述说明书

1. 建设目标

ShieldDome 是部署在企业 Linux 服务器上的钓鱼邮件检测平台。首版以风险提示、SOC 告警和复核闭环为目标，不自动隔离邮件。系统支持 Web 上传`.eml`测试，并通过 RFC822/EML API 为后续企业邮箱接入提供统一入口。

2. 适用场景

- 外部攻击者仿冒企业系统、供应商或上级单位。
- 合法内部或上级单位邮箱被盗后发送敏感操作请求。
- 显示链接与真实地址不一致、相似域名和 Punycode 欺骗。
- 恶意附件、宏、脚本、压缩包和二维码诱导。
- SOC 导入历史案例、可信模板和制度规则形成可审核 RAG 知识库。

3. 检测机制

检测由四层组成：

1. 确定性规则：邮件认证结果、链接结构、域名、敏感词和附件指标。
2. 静态分析：MIME、附件哈希、真实类型、宏标记、压缩包内容和脚本扩展名。
3. RAG：检索可信邮件、钓鱼案例、安全规则和 SOC 结论，提供可追溯引用。
4. LLM API：基于脱敏后的结构化特征辅助识别复杂语义意图。

LLM、Embedding 或外部附件服务不可用时，任务以`degraded`状态完成，规则与已有 RAG 能力继续工作。

4. 数据保护

- 原始邮件和附件默认保留 72 小时，使用`scripts/cleanup.py`删除。
- 脱敏结果、知识和审计记录默认保留 180 天。
- LLM 不接收原始附件；正文在本地执行实体脱敏后才进入模型上下文。
- API Key 仅从`/etc/shielddome/shielddome.env`读取。

5. 当前限制

- SPF、DKIM、DMARC 首版解析邮件服务器已写入的`Authentication-Results`，不自行进行 DNS 验证。
- 二维码解码和附件杀毒/沙箱采用可插拔外部服务，未配置时会显示降级状态。
- 单机部署不具备自动故障转移和无中断升级能力。

- 本地高权限账号未启用 MFA，属于已接受身份安全风险。